

Sprint 2: Authentication and Reliability

How SLE verifies Sendaza and prevents duplicate financial work

Delivered

Final status: authentication, replay protection, correlation IDs, idempotency, safe audit records, transactional outbox processing, signed Sendaza delivery, and worker crash recovery are implemented and verified. GitHub-hosted jobs remain externally blocked by the account-level Actions issue; local and Railway evidence is recorded below.

Before and Goal

Sprint 0 created the app and Sprint 1 added exact registries. Sprint 2 adds three safety layers: prove the caller is Sendaza, reject copied signed requests, and ensure retrying one financial instruction cannot create two effects.

Signed Request Flow

```
Sendaza builds method + URL + timestamp + nonce + body hash
-> signs with HMAC secret
-> SLE validates time, credential, and signature
-> PostgreSQL atomically stores hashed nonce
-> controller may run
```

The database stores key metadata and nonce hashes, never the HMAC secret. One or two environment-backed keys support rotation without downtime.

Idempotency Flow

```
Mutation + Idempotency-Key
-> hash operation, client, method, exact URL, exact body
-> unique database identity: client + operation + key
    first = ACQUIRED | same complete = REPLAY
    different body = KEY_REUSED | running = IN_PROGRESS
```

A financial module must complete its idempotency record in the same PostgreSQL transaction as its financial state change.

What Was Built

- Canonical HMAC-SHA256 signing, constant-time verification, and two-key rotation.
- Environment-only secrets plus Prisma credential metadata and atomic nonces.
- A global authentication guard with exact raw-body and request-target signing.
- Request hashing, stored response replay, conflict detection, and explicit mutation operations.
- Safe audit outcomes that exclude bodies, signatures, secrets, and complete nonces.
- Transaction-bound outbox enqueue, bounded leases, retry, delivery, recovery, and quarantine.
- An exact-body signed Sendaza publisher and a non-overlapping, gracefully stopping worker.

System Link

Purchases, withdrawals, and manual actions reuse these controls. Authentication fixes the caller identity as `sendaza-core`. Idempotency stops retries from duplicating effects. Financial services can enqueue an event through their Prisma transaction so state and notification commit together. The worker later delivers that event to Sendaza using its durable event ID.

Rules Protected

- Customer frontends never call SLE directly.
- Secrets never enter PostgreSQL or logs.
- Every financial mutation needs a stored request hash.
- Process memory is not replay or idempotency truth.
- Infrastructure uncertainty fails closed.

Evidence and Remaining Work

The final local gate passed 21 suites and 90 tests, typecheck, lint, and both builds. Railway PostgreSQL verified nonce uniqueness, concurrent idempotency, non-overlapping outbox claims, delivery, quarantine, expired-lease recovery, and atomic commit/rollback of state plus event. The production WorkerModule reclaimed a simulated crash lease, delivered one correctly signed event to a local Sendaza receiver, and stored delivery only after a `202` acknowledgement. Scoped test data was removed.

- Configure the real Sendaza sandbox webhook URL and secret during integration.
- Restore GitHub-hosted CI after the external account-level Actions block is resolved.
- Sprint 3 will add market-data adapters and conversion routes on this foundation.

Next Sprint

Sprint 3 adds market-data providers and conversion routes on this authenticated, retry-safe, durable foundation.

Glossary

HMAC: shared-secret message signature. **Nonce:** one-time replay detector. **Idempotency:** retrying has no extra effect. **Request hash:** digest binding a key to content. **Outbox:** durable records for post-commit event delivery.

Feature branch and canonical SLE documents. Final Sprint 2 evidence updated 31 August 2026.